

Evaluating CI/CD Pipeline Vulnerabilities and IAM Misconfigurations

John Smith

April 2026

Domain: Cloud Security

Abstract

Identity and Access Management (IAM) misconfigurations are a leading cause of cloud security breaches. This paper outlines the common pitfalls associated with overly permissive IAM roles in CI/CD pipelines. We propose a least-privilege enforcement framework and test its viability against common attack vectors. The findings suggest that adopting strict Role-Based Access Control (RBAC) mitigates the majority of lateral movement risks in cloud deployments.

1 Introduction

Cloud environments rely heavily on Identity and Access Management (IAM) to regulate permissions. When CI/CD pipelines are granted broad administrative privileges, they become lucrative targets for attackers. Compromising a build server can lead to full environmental compromise.

2 Methodology

We established a simulated AWS environment utilizing Terraform to provision infrastructure. We intentionally introduced overly permissive IAM roles into the GitHub Actions deployment pipeline. Subsequently, we executed automated attack scripts to attempt privilege escalation and lateral movement. Following the baseline test, we applied our proposed least-privilege framework and repeated the attack simulations.

3 Implementation and Findings

Instead of formal results, we present our implementation findings. The baseline simulation demonstrated that the compromised CI/CD pipeline could successfully assume a cross-account role and access sensitive S3 buckets within 3 minutes of the initial breach.

After applying the least-privilege framework, the attack scripts were denied access. The deployment pipeline was restricted to utilizing scoped, short-lived credentials via AWS STS. This effectively neutralized the credential theft vector.

4 Conclusion

Securing CI/CD pipelines requires rigorous IAM governance. By enforcing least privilege and utilizing ephemeral credentials, organizations can significantly reduce their attack surface.

References

- 1 Miller, T. (2023). *Cloud Native IAM Challenges*. Cloud Computing Security.
- 2 Davis, E. (2024). *Attacking the CI/CD Pipeline*. Hacker Quarterly.
- 3 Brown, S. (2025). *Zero Trust Architecture in Practice*. Security Press.